

IAM 정책 및 S3 버킷 정책 분석을 통한 권한 평가 보고서

1. 과제 개요

문제 상황

IAM 사용자 user01에게 필요한 AWS 권한을 부여하고, S3 버킷에 대한 접근 권한을 설정해야 한다.

또한 IAM 정책으로 EC2 전체 권한을 허용하더라도 Permission Boundary(권한 경계 정책)를 이용하여 특정 EC2 인스턴스에 대해서만 Start와 Stop 작업을 수행하도록 제한한다.

본 과제에서는 IAM 정책, S3 Bucket Policy, Permission Boundary를 작성하고 각 정책이 최종 권한에 어떠한 영향을 주는지 분석하였다.

2. IAM 정책 작성

정책(JSON)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "ec2:Describe*",
        "ec2:RunInstances",
        "ec2:TerminateInstances",
        "ec2:ModifyInstanceAttribute",
        "ec2:StartInstances",
        "ec2:StopInstances",
        "ec2:RebootInstances"
      ],
      "Resource": "*"
    }
  ]
}
```

정책 설명

IAM 정책은 IAM 사용자(user01)에게 EC2 서비스에 대한 권한을 부여하는 정책이다.

허용되는 작업

- EC2 조회(Describe)
- EC2 생성(RunInstances)
- EC2 수정(ModifyInstanceAttribute)
- EC2 삭제(TerminateInstances)
- EC2 시작(StartInstances)
- EC2 중지(StopInstances)
- EC2 재부팅(RebootInstances)

즉, IAM 정책만 적용된다면 user01은 EC2에 대한 대부분의 작업을 수행할 수 있다.

3. S3 Bucket Policy 작성 정책(JSON)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::<계정번호>:user/user01"
      },
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::버킷이름/*"
    }
  ]
}
```

정책 설명

S3 Bucket Policy는 리소스(Resource)에 대한 접근 권한을 설정하는 정책이다.
이번 정책에서는

- user01
- 지정된 S3 버킷

에 대해 s3:PutObject 권한을 허용하였다.
즉, user01은 해당 버킷에 파일을 업로드할 수 있다.

4. Permission Boundary 작성 정책(JSON)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "ec2:StartInstances",
        "ec2:StopInstances"
      ],
      "Resource": "arn:aws:ec2:*:*:instance/i-xxxxxxx"
    }
  ]
}
```

정책 설명

Permission Boundary는 사용자가 가질 수 있는 최대 권한(Maximum Permission)을 제한하는 정책이다.

이번 과제에서는 특정 EC2 인스턴스
i-xxxxxxx(AWS 계정 정보)에 대해서만

- Start
- Stop

작업을 수행할 수 있도록 제한하였다.

즉, IAM 정책에서 EC2 전체 권한을 허용하더라도 Permission Boundary가 적용되면 최종 권한은 Start와 Stop만 가능하다.

5. 권한 평가 결과

서비스	작업(Action)	결과	이유
EC2	DescribeInstances	✔	허용 IAM 정책
EC2	RunInstances	✖	제한 Permission Boundary
EC2	ModifyInstanceAttribute	✖	제한 Permission Boundary
EC2	TerminateInstances	✖	제한 Permission Boundary
EC2	StartInstances	✔	허용 Permission Boundary
EC2	StopInstances	✔	허용 Permission Boundary
S3	PutObject	✔	허용 Bucket Policy 허용

6. AWS 정책 평가 방식

AWS는 여러 정책이 동시에 적용될 경우 다음 순서로 권한을 평가한다.

1. Explicit Deny (명시적 거부)
2. Permission Boundary
3. IAM Policy
4. Resource Policy (Bucket Policy)
5. 기본 Deny

Permission Boundary는 사용자가 가질 수 있는 최대 권한을 제한하는 역할을 수행한다.

7. 결론

이번 실습에서는 IAM Policy, Bucket Policy, Permission Boundary의 역할을 확인하였다. IAM 정책은 사용자에게 EC2 관련 권한을 부여하고, Bucket Policy는 S3 버킷에 대한 객체 업로드 권한을 부여하였다. 또한 Permission Boundary를 이용하여 IAM 정책에서 허용한 EC2 전체 권한을 제한하여 특정 EC2 인스턴스의 Start와 Stop만 수행할 수 있도록 설정하였다. 이를 통해 AWS에서는 여러 정책이 동시에 적용될 경우 Permission Boundary를 이용하여 사용자의 최대 권한을 제한할 수 있음을 확인하였다.